Clase 1 · Esquema de seguridad, ciclo PTCA y auditorías

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · jueves 27 ago 2026 · Tema 1 · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

1. Pérdidas, riesgo y esquema de seguridad

- Pérdida **nula**: sí hay pérdida, pero insignificante ("sí me dolió, pero no me va a impactar tanto"). (La parcial no se profundizó; audio inaudible.)
- **Riesgo:** "la posibilidad de cualquier daño o pérdida".
- **Esquema de seguridad:** identificar los bienes y garantizar su resguardo respondiendo:

1. ¿Qué quiero proteger?
2. ¿De qué lo quiero proteger?
3. ¿Cómo lo voy a proteger?

- **Amenaza** = lo que puede pasar; **ataque** = cuando ya se materializa.
- Bien **intangible** (la vista) vs. **tangible** (el ojo, la córnea).

> **Principio (examen)**
> El **ser humano es el eslabón más débil**: falta de concientización, exceso de confianza, descuido de sus activos. La seguridad es inversión continua, no gasto.

2. Ciclo PTCA / PDCA (mejora continua, Deming)

Fase	Qué se hace	Ejemplo
P Planear	Jerarquizar bienes, analizar qué les puede pasar, decidir cómo protegerlos; recursos, presupuesto, metodología	Sismo sin plan = caos
T/D Hacer	Implementar; **simulacros** para que no quede en papel	Simulacro del 19 de septiembre
C Verificar	Comprobar si funciona; actualizar o retirar medidas	Simular fuga de agua o caída de servidor
A Actuar	Decidir con base en lo observado qué se mantiene y qué cambia; reiniciar el ciclo	Ajustar calendarios y responsables

3. Auditorías

Mínimo 2 al año (ideal cada 6 meses).

Nivel	Quién	Emite certificado

1.º interna	La propia organización, alguien que conoce los estándares pero no trabaja a diario con el auditado; checklist y preguntas	No
2.º externa	Empresa capacitada: ensayo o segunda opinión	No
3.º externa	Certificadora autorizada; servicio pagado, hasta una semana	**Sí**

Auditoría interna en la UNAM (examen)

Que personal de **FES Aragón** (o Geofísica) audite una dependencia de CU **sigue siendo interna**: comparten la misma legislación y reglamentos. La UNAM tiene 31 laboratorios certificados (meta 33), con auditorías cruzadas.

Regla de certificación

Si **un solo** departamento del alcance tiene una no conformidad sin resolver, **toda la organización pierde la certificación**. Por eso se certifica "poco a poquito" y se definen bien los alcances.

- Estándar del curso: ISO/IEC 27002 (audio poco claro: "27,2").

4. Hallazgos de auditoría

Hallazgo	Gravedad	Ejemplo
Oportunidad de mejora	La más leve: funciona; la empresa decide si aplica	Digitalizar formatos (puede justificar no hacerlo)
Observación	Algo se hace mal sin afectar la viabilidad; diferencia entre lo documentado y lo real	Faltan evidencias de la capacitación 2026
No conformidad	La más grave: pone en riesgo el proceso	Plazo para corregir; si no, se niega, bloquea o revoca el certificado

- La vigencia depende de la versión del estándar: si cambia, hay fecha límite para adaptarse (ISO 9001:2015 obligó a evaluar impacto ambiental en los laboratorios de la FI).

Pendiente

- Enviar por correo la lista del equipo con todos los correos; descargar el reglamento.
- En el aula: sin fotos, sin comer ni beber; celular solo para actividades guiadas; tolerancia de 15 minutos.

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Concepto	Para recordar
Esquema	Qué proteger, de qué, cómo
Eslabón débil	El ser humano
PTCA	Planear, Hacer, Verificar, Actuar (Deming)
Auditorías	≥ 2 al año; 1.º interna, 2.º externa sin certificado, 3.º certifica
Hallazgos	Oportunidad de mejora < observación < no conformidad
Regla	Una no conformidad = toda la organización pierde el certificado